

Volume 12

Enterprise & High-Assurance Architecture

Version: 1.0

Status: Draft

Chapter 1

Vision

Project Sentinel shall be capable of protecting environments ranging from a single home computer to large enterprise and government infrastructures.

The architecture shall support increasing assurance levels without redesigning the platform.

Chapter 2

High-Assurance Design Principles

The platform shall emphasize:

- Least Privilege
 - Zero Trust principles
 - Defense in Depth
 - Strong Authentication
 - Secure Defaults
 - Complete Auditability
 - Explainable Decisions
 - Controlled Automation
 - Resilience
 - Recoverability
-

Chapter 3

Trust Zones

Every deployment may define trust zones.

Example:

Internet

Security policies become stricter as trust levels increase.

Chapter 4

Identity Assurance

The platform shall support integration with enterprise identity providers using open standards.

Examples include:

- OpenID Connect (OIDC)
- SAML 2.0
- LDAP / Active Directory (where applicable)

Multi-factor authentication should be supported for administrative access.

Chapter 5

Approval Workflows

Sensitive operations should support configurable approval workflows.

Examples:

- Delete assets
- Disable accounts
- Change security policies
- Approve automated remediation
- Export sensitive reports

Organizations can require one or more approvers based on policy.

Chapter 6

Immutable Audit Trail

Every important action generates an audit record.

Examples:

- Login
- Scan started
- Scan completed
- Policy changed
- Plugin installed
- User created
- Role modified
- Report exported
- Remediation approved

Audit records should be protected against unauthorized modification.

Chapter 7

Role-Based Access Control (RBAC)

Permissions are granted to roles rather than directly to users.

Initial system roles include:

- Platform Administrator
- Security Administrator
- SOC Analyst
- Incident Responder
- Security Consultant
- Auditor
- Compliance Officer
- Asset Manager
- Executive Viewer
- Standard User

Organizations can create custom roles by combining permissions.

Chapter 8

Security Profiles

The same platform can operate with different security profiles.

Examples:

Home

Simplified interface.

Professional

Expanded technical controls.

Enterprise

Workflow approvals and centralized management.

Government

Offline operation, enhanced auditing, stricter policy enforcement.

Profiles change configuration, not architecture.

Chapter 9

Industry Compliance Framework

The platform architecture shall support mapping controls to multiple frameworks. Rather than hard-coding a single standard, the Compliance Engine maps evidence to frameworks such as:

- ISO/IEC 27001
- NIST Cybersecurity Framework (CSF)
- CIS Controls
- PCI DSS
- SOC 2

Additional frameworks can be added as plugins or policy packs.

Chapter 10

Operational Resilience

The platform should continue operating during partial failures.

Examples:

- Loss of internet connectivity.
- Failure of a worker process.
- Temporary storage latency.
- Plugin failure.

Core functions remain available whenever possible.

PS-ADR-0009

High-Assurance by Configuration

Status: Accepted

Decision

Project Sentinel shall provide a single core platform capable of operating at different assurance levels through policy, configuration, and deployment choices rather than maintaining separate codebases.

Rationale

A single architecture reduces maintenance effort, improves consistency, and allows organizations to adopt stronger controls as their security requirements grow.

New Proposal - Security Assurance Levels (SAL)

I believe Project Sentinel should define its own **Security Assurance Levels** for deployments.

For example:

Level	Typical Use
-------	-------------

SAL-1	Home users and students
-------	-------------------------

New Proposal – Architecture Review Board (ARB)

As the project grows, we should establish an Architecture Review Board within the project.

Its responsibilities include:

- Reviewing new core modules.
- Approving architecture changes.
- Reviewing security implications.
- Preventing unnecessary complexity.
- Ensuring compliance with Blueprint principles.

Even if you are the primary owner today, having a documented governance process will make the project more sustainable if other contributors join later.

A strategic recommendation

If our long-term ambition is for Project Sentinel to be used by banks, cryptocurrency companies, governments, and other high-security organizations, then we should design every core component to be **deterministic, explainable, and auditable**.

That means:

- No unexplained AI decisions.
- Every recommendation links to supporting evidence.
- Every automated action is traceable.
- Every permission is explicit.
- Every architectural decision is documented.
- Every security assessment clearly states its confidence and limitations.

I believe this philosophy will distinguish Project Sentinel from many existing platforms and make it suitable for environments where trust, accountability, and regulatory scrutiny are as important as technical capability.

=====[USER]=====

Good and continue

=====[ASSISTANT]=====

Excellent. I think we have now reached the point where Project Sentinel starts to become **a cybersecurity platform with its own identity**, instead of a collection of security modules.

From now on, one rule will guide every engineering decision:

Every feature must help the user make a better security decision.

Not just generate more data.

PROJECT SENTINEL BLUEPRINT

Volume 13